AI Policy Toolkit · Handbook

The reasoning behind every document, with sources and dates

Sources read at the originals on 18 and 19 October 2026

0 How to use this toolkit

The toolkit turns about thirty answers into seven dated documents. This handbook explains why each document says what it says, which source stands behind it, and where the business decides for itself. You do not need to read it before you start. Every question in the generator names the section of this handbook that explains it.

The seven documents. D1 the AI usage policy, nine sections, signed by the management. D2 the one page to post: what never goes into a tool, what is checked, who is asked. D3 the tool register with one row per tool and an approval form with seven questions per tool. D4 the briefing record: attendance list per group and an overview per person. D5 the labelling checklist under Article 50 of the AI Act. D6 the enactment plan with fifteen steps and the review sheet. D7 the evidence summary: dated, with a document number, what is regulated and what is open.

What the toolkit is not. It is not legal advice and no document claims that the business complies with a rule. The documents show what the business has decided, since when, for which tools, and who knows about it. Where a source is missing, the handbook says so and leaves the decision with the business instead of inventing a rule.

The four markers. Every statement that matters carries one of four markers. Fact: wording or date read at the original source, which is named with its retrieval date. Interpretation: a conclusion Scutoria draws from the sources; it can be argued with. Uncertain: the sources contradict each other or the legal situation is open; the handbook says what was checked and when. Gap: no source answers the question; the business decides and the document leaves the field open on purpose.

The example business. The generator is prefilled with a fictional electrical contractor with ten to forty-nine staff in Austria: an owner who is also the management, an office manager, two more people in the office, field staff and one apprentice. Three people in the office use a text assistant for quotes, summaries and translations; two field staff set it up privately on their phones. No person in this handbook is real.

The order of work. Answer the questions. Read D1 and D2. Fill the register at the providers' pages. Post the one page. Hold the briefing. Create the labelling checklist or the note "no case

at present". Sign the policy, enter the review date, file everything in one folder. Section 6 walks through the fifteen steps.

1 Why a policy, and what it is not

◆ INTERPRETATION Neither the AI Act nor the General Data Protection Regulation contains a provision that explicitly requires a business to keep a written AI usage policy. We read the articles that come closest: Article 4 of the AI Act asks for measures that support AI literacy, Article 24(1) of the GDPR asks the controller for technical and organisational measures that are reviewed and updated where necessary, and the Trade Secrets Directive protects information only if reasonable steps were taken to keep it secret. None of them says "policy". A policy is the usual way to meet all three at once, not a duty of its own.

→ Source: Regulation (EU) 2024/1689, Art. 4; Regulation (EU) 2016/679, Art. 24(1); Directive (EU) 2016/943, Art. 2(1)(c) · EUR-Lex · retrieved 2026-10-18 and 2026-10-19

■ FACT The German data protection authorities recommend exactly such a policy. Their guidance of 6 May 2024 says that clear internal instructions should be issued and documented on whether, under which conditions and for which concrete purposes which AI applications may be used, and that concrete examples of permitted and prohibited scenarios are recommended.

→ Source: Datenschutzkonferenz, Orientierungshilfe Künstliche Intelligenz und Datenschutz, version 1.0 of 6 May 2024, section 2.2, p. 10 · datenschutzkonferenz-online.de · retrieved 2026-10-18

■ FACT The German Federal Office for Information Security says the same from the security side. Its measure M16 asks employers to inform users which AI models and applications they may use for which purposes, which inputs they may make and how they may reuse outputs, and to lay those rules down bindingly, for example in policies.

→ Source: BSI, Generative KI-Modelle, Chancen und Risiken für Industrie und Behörden, version 2.0 of 17 January 2025, measure M16, p. 49 · bsi.bund.de · retrieved 2026-10-18

■ FACT The Austrian Economic Chamber publishes a free model policy for employees with nine numbered paragraphs in its AI guidelines for SMEs, third edition, April 2026. Section 7 says what it covers, what it lacks and where it is out of date.

→ Source: Wirtschaftskammer Österreich, KI-Guidelines für KMU, 3rd edition, April 2026, pp. 14 to 27 · wko.at · retrieved 2026-10-18

◆ INTERPRETATION These three bodies are German and Austrian. Their recommendations are professional practice, not law, and they bind nobody outside their countries. They are still the best published reasoning we found, and the nine areas of the policy follow them.

FACT The strongest reason for the area on prohibited inputs is the trade secret. Under the Trade Secrets Directive, information is a trade secret only if it meets three conditions, the third being that it "has been subject to reasonable steps under the circumstances, by the person lawfully in control of the information, to keep it secret".

→ Source: Directive (EU) 2016/943, Art. 2(1)(a) to (c) · EUR-Lex · retrieved 2026-10-18

◐ UNCERTAIN

Does an AI usage policy count as a reasonable step to keep information secret?

No court decision was searched for this question. The handbook therefore says only this: without a rule, there is no evidence that the business took any step at all; with a rule, the business can show that it did. Whether that step is "reasonable" is decided case by case.

LAST CHECKED 2026-10-19 · OPEN POINT 8.12

◆ INTERPRETATION Four things make a text a rule in force: a date from which it applies, a named responsible person, a traceable way in which it was announced, and a confirmation that each person received it. No source lists these four. They follow from the supervisory wording that instructions should be "issued and documented": a paper in a drawer is documented, but it was never issued.

What a policy does and does not do. It does not create a liability shield and it does not replace the choice of a tool. It makes a use that is already happening visible, it moves individual decisions from each employee to the business, and it is itself a protective measure that legal consequences can attach to. The toolkit claims nothing beyond that.

2 The nine areas of the policy

Each area is one section of D1. For each, the handbook says what the section rules, why, which answer decides it, and what the example business did.

2.1 Permitted tools and access (§ 1)

What it rules. Only tools listed as approved in the register may be used for work; the register names the keeper (question A5). Use takes place through the access the business provides. Private accounts are either not permitted or permitted only for listed tasks (question B4). Business accounts carry no personal names and use a functional address; question B5 names who manages them.

■ FACT The data protection authorities advise that employees should not have to work with AI applications through private accounts and devices, because profiles of individual employees can arise that way. Accounts should not contain the names of individual employees where the application does not run on the business's own servers, and a functional email address of the business is called for where an address is requested.

→ Source: Datenschutzkonferenz, Orientierungshilfe of 6 May 2024, section 2.4, pp. 10 to 11 · retrieved 2026-10-18

◆ INTERPRETATION A rule that only names the tool silently permits its use through a private account. The rule must therefore name the tool and the access path. In the example business, two field staff with a privately installed assistant are the reason this field cannot be filled with "as before": either they get access through a business account, or their work use on the private phone ends on the effective date.

2.2 Permitted and prohibited uses (§ 2)

What it rules. The permitted uses are the tasks that actually occur in the business (question C1), not categories from a template. One prohibition is fixed and is not asked: no final decision about a person is based on an AI result. Question C2 adds the business's own exclusions.

■ FACT Annex III of the AI Act lists as high-risk the AI systems intended for recruitment or selection of natural persons, for placing targeted job advertisements, analysing and filtering applications and evaluating candidates, and the systems intended to make decisions affecting terms of work relationships, promotion or termination, to allocate tasks based on individual behaviour or traits, or to monitor and evaluate performance and behaviour.

→ Source: Regulation (EU) 2024/1689, Annex III, point 4(a) and (b), consolidated version of 27 July 2026 · EUR-Lex · retrieved 2026-10-19

■ FACT The obligations for Annex III high-risk systems apply from 2 December 2027; the amending Regulation (EU) 2026/1744 moved that date from August 2026. Prohibited since 2 February 2025 is the use of AI systems to infer the emotions of a natural person in the workplace, except for medical or safety reasons.

→ Source: Regulation (EU) 2024/1689, Art. 113, point (c)(i) and Art. 5(1), point (f), consolidated version of 27 July 2026 · EUR-Lex · retrieved 2026-10-19

◆ INTERPRETATION The policy is the place where a business without an IT department excludes these uses before the duties for them become applicable. The prohibition names uses, not tools: the same text assistant that drafts a quote must not rank applicants. In the example business the permitted uses are quote drafts, summaries of manufacturer texts, translations for two field staff, and wording help for complaints; everything that concerns applications or the assessment of individual employees is excluded.

2.3 Prohibited inputs (§ 3)

What it rules. Five kinds of data never go into a tool, whatever the access: data about customers, staff and applicants by which a person can be identified; access data, passwords, keys and access codes; calculations, prices, contracts, customer lists and other information the business keeps confidential; health data; documents of third parties handed over in confidence. Question D1 adds the business's own kinds. The rule of doubt closes the list: in case of doubt nothing is entered, and the person named in § 9 is asked.

◆ INTERPRETATION A list without a rule of doubt is incomplete, because no catalogue meets every case. The rule of doubt also stands first on the one page, for the same reason.

■ FACT The trade secret reasoning is in section 1. The example business added the calculation sheets per job and the access codes to customer sites.

2.4 Handling unavoidable personal data (§ 4)

What it rules. Question E1 chooses one of three rules: a task with personal data is not done with an AI tool; the text is drafted with placeholders and the details are inserted afterwards outside the tool; or the task is done only in a tool that the register approves for personal data.

■ FACT The data protection authorities state that, to avoid entering personal data, it is regularly not enough to remove names and addresses from an input, because the connection to a person can be restored from the context, especially with applications whose purpose is to create cross-references from unstructured data.

→ Source: Datenschutzkonferenz, Orientierungshilfe of 6 May 2024, section 3.1, p. 12 · retrieved 2026-10-18

■ FACT Entering personal data into an AI application and transferring it to the provider each need a legal basis under the GDPR. The guidance also treats the question whether the provider trains on the inputs as decisive for the choice of tool.

→ Source: Datenschutzkonferenz, Orientierungshilfe of 6 May 2024, sections 1.9 and 3.1, pp. 7 and 12 · retrieved 2026-10-18

◆ INTERPRETATION The placeholder rule is the practical middle way for a small business: the complaint letter is written with "[customer]" and "[site]", and the office manager inserts the details afterwards. The example business chose this rule.

2.5 Review before use (§ 5)

What it rules. Every result is read and checked by the person using it before it is used. Figures, names, deadlines and references are always checked; question F1 adds what the business checks in addition, such as standards, article numbers, prices or legal citations.

■ FACT The BSI asks that users are enabled to question the outputs of a model critically, to adjust their content where needed and to restrict their reuse.

→ Source: BSI, Generative KI-Modelle, version 2.0 of 17 January 2025, M16, p. 49 · retrieved 2026-10-18

◆ INTERPRETATION A general duty to check is read as a formality. The rule therefore names what is checked. The example business added standard references in quotes, because the assistant invents standard numbers in the correct format.

2.6 Release of documents leaving the business (§ 6)

What it rules. Documents produced or edited with an AI tool that leave the business are released by a named person or function (question A9), with a deputy.

◌ GAP No source we read requires a release by a second person. The section is the organisational counterpart of the review duty: whoever drops it puts the whole review on the author. The business may remove the section; the handbook only says what that means.

2.7 Labelling (§ 7)

What it rules. A named person (question A6) decides whether and how it is disclosed that content was generated or altered with AI, using the labelling checklist D5. Internal drafts and individual correspondence that a person checks and sends are not labelled.

◆ INTERPRETATION Two opposite mistakes are common: labelling nothing where it is required, and labelling everything as a precaution. A sentence such as "as far as legally required" hands the decision back to each employee and is therefore not a rule. Section 5 explains the three cases of Article 50 that concern a deployer.

2.8 Reporting incidents (§ 8)

What it rules. Anyone who notices that something confidential went into a tool by mistake, or that a faulty result left the business, reports it to the person named in question A7. The report itself has no consequences for the person reporting.

◆ INTERPRETATION No source we read requires such a channel. It follows from incentives: a business that punishes the report learns about incidents last. The no-consequence sentence is fixed in D1 and not a question for that reason.

2.9 Responsibility in case of doubt (§ 9)

What it rules. Anyone unsure whether a task, an input or a tool is permitted asks the person named in question A8 before entering anything.

■ FACT The data protection authorities advise that data protection officers should always be involved when decisions about AI applications are prepared or taken, and that the involvement of works councils is to be considered and examined.

→ Source: Datenschutzkonferenz, Orientierungshilfe of 6 May 2024, section 1.12, p. 8 · retrieved 2026-10-18

◆ INTERPRETATION A business without a data protection officer, like the example business, names a person instead. What matters is that the person is reachable: the policy states how.

2.10 Head, closing and the one page

What it rules. The head carries the business, the effective date (question I1), a version line and the responsible person (question A4). The closing says how the policy is announced, when it is reviewed (question I2) and where the evidence is kept (question I3), and ends with the signature of the management.

◆ INTERPRETATION The effective date should lie after the briefing: a rule nobody knows is worse than none, because it pretends safety. The version line carries a date so that a later change shows which version applied when.

The one page (D2). It contains no section in full, but three things: what never goes into a tool, with boxes to tick during the briefing; what is checked before use; and who is asked and where incidents are reported. Its content is taken from the policy, never decided separately, so that poster and policy cannot contradict each other.

3 Tools, accounts and the seven questions

The tool register (D3) answers the question nobody can answer without a rule: which tools are used in the business, by whom, for what, through which account, with which data, and which of them are checked. The approval form is the decision per tool.

The register. One row per tool actually in use, prefilled from questions B1 and B2: tool kind, name and provider, purpose, users, account kind, data kinds, approval, review date, review due. A row without a date is not evidence. Tool names are allowed here, unlike in the handbook, because the review date stands next to them. The entry "unclear" is a finding, not a failure: a tool that is used but not checked stands in the register with "unclear" and gets a review date. Private accounts get "no" with the reason § 1.

The seven questions. Questions 1 to 4 are the contractual criteria; 5 and 6 come from the guidance on accounts and default settings; 7 is a classification the business usually cannot make itself.

1. Training with business data: are inputs used to train the models, and can this be excluded or opted out?

2. Data processing agreement: is one offered, and for which services?
3. Place of processing: is there a reliable commitment to processing in the Union, and with which exceptions?
4. Third-party rights: does the provider indemnify against third-party claims, and what is excluded, typically the business's own inputs?
5. Deletion and input history: can it be set that no input history is kept beyond the session and that inputs are not used for training?
6. Access and account kind: is there a business account without personal names, with a functional address, and who manages it?
7. Lawfulness of model development: is there an official or court finding about the provider? A business without a legal department usually leaves this as "not surveyed", which is more honest than a tick.

■ FACT The data protection authorities advise that, for accounts employees are to use, the functions for training and input history should be set at the time the account is put into operation so that no inputs are processed for training purposes and no input history is kept beyond the session, and that outputs belonging to the account must not be published automatically.

→ Source: Datenschutzkonferenz, Orientierungshilfe of 6 May 2024, section 2.5, p. 11; on input history also section 1.10, p. 7 · retrieved 2026-10-18

■ FACT Where a provider processes personal data on behalf of the business, the GDPR requires a contract or other legal act that binds the processor; that is the data processing agreement of question 2.

→ Source: Regulation (EU) 2016/679, Art. 28(3) · EUR-Lex · retrieved 2026-10-19

◆ INTERPRETATION Each question is checked at the provider's own page or contract, not at an article about the provider, and the concluded contract prevails over a product page. A blank field is a finding ("no statement on the page checked"); a filled field without source and date is not. The toolkit names no provider and ships no filled approval list, because a list would be wrong the moment a provider changes its terms.

The standard of the business. Question I4 sets the benchmark that applies to every tool alike: no approval for personal data without a data processing agreement; no approval without the exclusion of training; or a decision per tool. The toolkit recommends none of the three, because the right one depends on what the business does with the tool.

When a tool is checked again. On the review date, and whenever the provider changes its terms, whichever comes first.

4 Training: Article 4 of the AI Act

■ FACT Article 4(1) reads: "Providers and deployers of AI systems shall take measures to support the development of AI literacy of their staff and other persons dealing with the operation and use of AI systems on their behalf, taking into account their technical knowledge, experience, education and training and the context the AI systems are to be used in, and considering the persons or groups of persons on whom the AI systems are to be used. This obligation does not require providers or deployers to guarantee any specific level of AI literacy of any individual." The article has applied since 2 February 2025. The second sentence was added by Regulation (EU) 2026/1744, in force since 27 July 2026.

→ Source: Regulation (EU) 2024/1689, Art. 4(1) and Art. 113, point (a), consolidated version of 27 July 2026; Regulation (EU) 2026/1744, Art. 1, point (5) · EUR-Lex · retrieved 2026-10-18 and 2026-10-19

■ FACT The European Commission answers the question how this is to be documented: "There is no need for a certificate. Organisations can keep an internal record of trainings and/or other guiding initiatives." It adds that the persons covered are not only employees but persons broadly under the organisational remit, such as a contractor, a service provider or a client. The page is guidance, not law.

→ Source: European Commission, AI literacy, questions and answers, page dated 27 July 2026 · digital-strategy.ec.europa.eu · retrieved 2026-10-18

◆ INTERPRETATION The duty is narrower than it is often presented. It asks for measures that support literacy, considering prior knowledge and context. It prescribes no format, no minimum duration and no certificate. The briefing record (D4) is the internal record the Commission describes: it shows that a briefing took place, when, with whom and with which contents. It does not show that the briefing was sufficient, and no source we read says what sufficient is.

The briefing record. One sheet per briefing with date, duration, conducting person (question H1), form and target group, the contents covered as a checklist, and the attendance list with name, function and signature. The eight contents mirror the toolkit: the policy section by section; the permitted tools and why private accounts are not used; what never goes in and the rule of doubt; two or three use cases from the business; the typical failure patterns, invented figures, names, deadlines and references in the correct format, and what is checked; the reporting channel and that the report has no consequences; when and how to label; who is asked in case of doubt. Question H2 decides whether there is one briefing for all or one per group.

■ FACT The duty asks to take into account the technical knowledge, experience, education and training of the persons and the context the systems are used in. A briefing that is the same for everyone therefore fits only if everyone does the same. In the example business the office gets a longer briefing with use cases, the field staff a shorter one on § 1 and § 3.

→ Source: Regulation (EU) 2024/1689, Art. 4(1) · retrieved 2026-10-19

The overview per person. One row per person who uses AI tools for work, including freelancers and contractors working with business tools (question A11): function, first and last briefing, contents, date of acknowledgement of the policy, next briefing, remarks. Names are entered by the business, never by the generator.

◌ GAP How often the briefing is repeated (question H4) and how long the record is kept (question H5) is stated in no source we read. Both fields are open on purpose. A new or changed tool is an obvious occasion to repeat; the business sets the rhythm.

◐ UNCERTAIN Supervision of Article 4 starts with the general application of the AI Act. The Commission's page says in one answer "The supervision and enforcement rules apply from 3 August 2026 onwards" and in another "as of 2 August 2026". The Regulation itself applies from 2 August 2026, and its chapter on penalties since 2 August 2025. Article 4 is not in the catalogue of fines in Article 99(3) to (5); consequences follow the rules each member state adopts under Article 99(1). The handbook uses 2 August 2026 and records the contradiction.

→ Source: Regulation (EU) 2024/1689, Art. 99(1), (3) to (5) and Art. 113, consolidated version of 27 July 2026 · retrieved 2026-10-19; European Commission, AI literacy, questions and answers, page dated 27 July 2026 · retrieved 2026-10-18

■ FACT For high-risk systems more applies: deployers must assign human oversight to persons who have the necessary competence, training and authority, and the Commission confirms that this training duty remains. A business that uses a system for a purpose listed in Annex III does not get by with this record. The toolkit is built for general use, and § 2 excludes the high-risk cases.

→ Source: Regulation (EU) 2024/1689, Art. 26(2), consolidated version of 27 July 2026 · retrieved 2026-10-19; European Commission, AI literacy, questions and answers · retrieved 2026-10-18

■ FACT As a suggestion for contents, the Austrian Economic Chamber lists in its model paragraph 9: understanding AI and its fields of use, selecting and using suitable tools, needs analyses and use cases, the technical limits of AI, ethical aspects, legal aspects such as data protection, liability and copyright, and security. The description of the duty on the same page is out of date: it says the AI Act obliges businesses to "ensure" AI literacy and that the requirements apply "since the end of 2025". Article 4 asks to support, excludes a guaranteed level, and has applied since 2 February 2025; the chamber's own page 33 gives the correct date.

→ Source: Wirtschaftskammer Österreich, KI-Guidelines für KMU, 3rd edition, April 2026, pp. 25 to 26 and p. 33 · retrieved 2026-10-18; Regulation (EU) 2024/1689, Art. 4 and Art. 113 · retrieved 2026-10-19

5 Labelling: Article 50 of the AI Act

FACT Article 50 has applied since 2 August 2026. It addresses providers in paragraphs 1 and 2 and deployers in paragraphs 3 and 4. A deployer is a person or body "using an AI system under its authority except where the AI system is used in the course of a personal non-professional activity"; a provider develops a system or has it developed and places it on the market under its own name.

→ Source: Regulation (EU) 2024/1689, Art. 3(3) and (4), Art. 50, Art. 113, consolidated version of 27 July 2026 · EUR-Lex · retrieved 2026-10-19

FACT The Commission's guidelines on Article 50 say that where the deployer is a legal person, the individual employees acting under its instructions and control are not separate deployers, and that the legal person remains the deployer even if it involves contractors or freelancers under its responsibility. A company that merely commissions an agency without deciding whether and how the agency uses AI is not a deployer. Platforms, hosting services and broadcasters that only disseminate content created by others are not deployers either.

→ Source: European Commission, Guidelines on the implementation of the transparency obligations under Article 50 of the AI Act, C(2026) 5054 final of 20 July 2026, points 12, 14 and 16 · digital-strategy.ec.europa.eu · retrieved 2026-10-19

The three cases for a deployer. A business that uses tools made by others is addressed by three rules:

1. Emotion recognition or biometric categorisation (paragraph 3): the persons exposed are informed of the operation of the system. Question G4 asks whether the business does this; if yes, the toolkit points to a specialist, because the workplace use of emotion recognition is largely prohibited anyway.
2. Deep fakes (paragraph 4, first subparagraph): a deployer that generates or manipulates image, audio or video content constituting a deep fake discloses that the content has been artificially generated or manipulated. Where the content forms part of an evidently artistic, creative, satirical, fictional or analogous work, the duty is limited to disclosing the existence of such content in a way that does not hamper the display or enjoyment of the work.
3. Text on matters of public interest (paragraph 4, second subparagraph): a deployer that generates or manipulates text "which is published with the purpose of informing the public on matters of public interest" discloses that it has been artificially generated or manipulated, unless the content has undergone human review or editorial control and a natural or legal person holds editorial responsibility for the publication.

FACT A deep fake is "AI-generated or manipulated image, audio or video content that resembles existing persons, objects, places, entities or events and would falsely appear to a person to be authentic or truthful". The information under paragraphs 1 to 4 is provided "in a clear and distinguishable manner at the latest at the time of the first interaction or exposure" and conforms to the applicable accessibility requirements.

→ Source: Regulation (EU) 2024/1689, Art. 3(60) and Art. 50(5) · retrieved 2026-10-19

The two provider rules, and what the business records about them. Paragraph 1 asks providers to design systems that interact with people so that the people are informed that they interact with an AI system, unless that is obvious. Paragraph 2 asks providers of generative systems to mark outputs in a machine-readable format. The business records in point 3 of the checklist what the provider states about both, and claims nothing itself.

FACT Providers of generative systems placed on the market before 2 August 2026 have until 2 December 2026 to comply with the marking duty of paragraph 2. The guidelines confirm that this transition concerns only the marking duty; the notice for interacting systems applies from 2 August 2026.

→ Source: Regulation (EU) 2024/1689, Art. 111(4), inserted by Regulation (EU) 2026/1744, Art. 1, point (39) · retrieved 2026-10-18 and 2026-10-19; Guidelines C(2026) 5054, point 153 · retrieved 2026-10-19

The nine points of the checklist (D5). Points 1 to 3 are standing and prefilled: role clarification per tool, inventory of uses from questions G1 to G4, provider evidence per tool. Points 4 to 9 are sheets per system or per publication: chatbot or voice assistant; deep fake check per image, audio or video; text check per publication; timing and form; key dates; delimitation. If all four inventory questions are answered with no, the checklist records "no case at present" with the date, and the review in the enactment plan asks the question again.

FACT The guidelines state that certain techniques are not necessary and, used alone, insufficient for the notice under paragraphs 1 and 5: disclosures contained only in terms and conditions, URLs or documentation; machine-readable markings that are not perceivable at the point of interaction; unclear signals such as a generic "assistant"; and generalised disclosures.

→ Source: Guidelines C(2026) 5054, point 38 · retrieved 2026-10-19

■ FACT On "matters of public interest" the guidelines give three elements. Published means accessible to an indeterminate, fairly large number of unrelated readers. Informing means communicating knowledge, opinions or facts; short texts without such content do not inform. Matters of public interest are those relevant to society at large and meriting public debate, such as politics, public administration, justice, fundamental rights, public security, public health, environmental protection, consumer safety and economic or financial questions. Outside the scope, according to the guidelines' own examples, are a company's advertisements and product descriptions that make no claims about health, consumer safety or sustainability, a consultant's advice to a client, and a chatbot summary visible only to the person who asked.

→ Source: Guidelines C(2026) 5054, point 131 with examples · retrieved 2026-10-19

■ FACT The exception for human review needs both conditions: the text has undergone human review or editorial control, and a natural or legal person holds editorial responsibility. Human review means the deliberate examination of the substance by persons with relevant knowledge; fact-checking is a minimum. Spell-checking, the mere existence of an editorial policy, automated review or a cursory approval do not count. Any substantive AI change after the review voids the exception. Editorial responsibility can be named online in the terms or legal information of a website and offline in a colophon.

→ Source: Guidelines C(2026) 5054, points 133 to 138 · retrieved 2026-10-19

■ FACT Content generated before 2 August 2026 need not be marked or labelled retroactively. Text generated before but published on or after that date needs the label. The Commission encourages labelling pre-existing deep fakes without disproportionate effort.

→ Source: Guidelines C(2026) 5054, point 154 · retrieved 2026-10-19

◆ INTERPRETATION Internal use without external effect and individual correspondence that a person checks and sends are not "published" in the sense of the guidelines, because they do not reach an indeterminate number of readers. The checklist says so, so that nobody labels every email as a precaution. For the example business, a website article about a new inspection duty for electrical installations is a text on a matter of public interest; the owner reviews it substantively and is named in the legal notice, and the checklist records the exception. An AI-generated image of a technician in front of a switch cabinet on the website is a deep fake, because it shows a real-looking scene that never happened; a stylised graphic of a lightning bolt is not. Advertising usually cannot rely on the artistic exception.

◐ UNCERTAIN **Does a business that embeds a provider's chatbot on its website have an own duty to show the notice?**

Paragraph 1 addresses the provider, which must design the system so that people are informed. The guidelines clarify who is a deployer, but not whether a deployer of an interactive system has an own duty under paragraph 1. The checklist therefore asks only to verify that the provider's notice appears before the first answer, and to keep a screenshot with a date.

LAST CHECKED 2026-10-19 · OPEN POINT 8.5

■ FACT Fines for breaches of the transparency obligations of Article 50 go up to EUR 15 000 000 or 3 % of the total worldwide annual turnover, whichever is higher; for SMEs the lower of the two amounts applies. Which authority supervises this in each member state is a matter of national law; section 7 records what is known.

→ Source: Regulation (EU) 2024/1689, Art. 99(4), point (g) and Art. 99(6), consolidated version of 27 July 2026 · retrieved 2026-10-19

■ FACT Labelling does not make a use lawful. Paragraphs 1 to 4 are without prejudice to other transparency obligations in Union or national law, and data protection, competition law, personality rights and copyright remain unaffected.

→ Source: Regulation (EU) 2024/1689, Art. 50(6) · retrieved 2026-10-19

6 Enacting and maintaining

◆ INTERPRETATION A rule does not apply because it is written. The part that is skipped most often in practice is enactment. Four things make a text a rule in force: an effective date, a named responsible person, a traceable way of announcement and a confirmation of receipt. The enactment plan (D6) is the sheet on which these four get a date.

The fifteen steps. Prefilled with the responsible persons from the answers and with the dates of briefing and effective date.

1. Name the person responsible for the rule.
2. Take stock: which tools are actually in use; create the register, also with "unclear".
3. Take the four decisions of the management: who may use, for what, with which data, who releases.
4. Complete the usage policy; no yellow passage left open.
5. Involve the works council and, where present, the data protection officer, before procuring new tools, not after.

6. Set up business accounts; set training and input-history options; use a functional address.
7. Approval check per tool, fill in the form, update the register.
8. Post the one page and put it in the staff folder.
9. Hold the briefing; have the attendance list signed.
0. Have each person confirm receipt of the policy.
1. Create the labelling checklist per system and per publication, or the dated note "no case at present".
2. Enter the effective date, sign the policy.
3. Set up the folder: one folder with the evidence.
4. Enter the review: date and occasions.
5. On every new hire: briefing and acknowledgement, add to the overview.

◐ UNCERTAIN Step 5 is a pointer, not a prescription. Whether an AI tool triggers the participation of the works council is national labour law and differs between member states; the GDPR itself leaves the processing of employees' data to more specific national rules. The German data protection authorities say the involvement of works councils is to be considered and examined. A business with a works council clarifies this with a specialist before procurement, because the same steps that are right for data protection, business accounts and default settings, lead into co-determination and not past it.

→ Source: Regulation (EU) 2016/679, Art. 88(1) · retrieved 2026-10-19; Datenschutzkonferenz, Orientierungshilfe of 6 May 2024, section 1.12, p. 8 · retrieved 2026-10-18

The four occasions and the fixed date. The review sheet lists four occasions: a new or changed tool; changed terms of a provider; a changed legal situation; practice that deviates from the rule, in which case the business decides which of the two changes. Question I2 sets the fixed date, six or twelve months after the effective date, so that the review does not depend on somebody noticing a change.

■ FACT Where personal data are involved, the review is in the Regulation itself: the controller's technical and organisational measures "shall be reviewed and updated where necessary".

→ Source: Regulation (EU) 2016/679, Art. 24(1) · EUR-Lex · retrieved 2026-10-19

◌ GAP No source names an interval. The toolkit offers six or twelve months and recommends neither; the example business chose twelve months and every occasion.

The evidence summary (D7). One page with the business, a document number, the date of preparation, the review date, and one line per piece of evidence with the status regulated, planned or open. Open items are listed, not hidden. The page describes what the business decided and documented; it does not certify compliance.

When it is done. When one folder, on paper or as files, holds the signed policy with effective date and version line, the register with a date in every row and an approval form per approved tool, the signed attendance lists and the overview per person, the labelling checklist or the dated note, the enactment plan with a date in every row, and the evidence summary. Together they answer one question: what have we regulated, since when, for which tools, and who knows about it.

7 Country notes

The Union rules in sections 4 and 5 apply in every member state. What differs is who supervises them, which national bodies publish guidance, and whether a works council has a say. The toolkit checked Austria and Germany and names the gap for the rest.

7.1 Austria

■ FACT The Austrian Economic Chamber publishes free AI guidelines for SMEs with a model policy for employees in nine paragraphs from page 14. The third edition is dated April 2026 and therefore predates Regulation (EU) 2026/1744 of 8 July 2026. Several passages no longer match the consolidated text: pages 5, 11, 17, 20, 29 and 39 say that the rules for high-risk systems apply from August 2026, while Article 113 now says 2 December 2027 for Annex III and 2 August 2028 for Annex I; page 26 says the AI Act obliges businesses to ensure AI literacy and that this applies since the end of 2025, while Article 4 asks to support literacy, excludes a guaranteed level and has applied since 2 February 2025. The guidelines call themselves work in progress and point to the current version online.

→ Source: Wirtschaftskammer Österreich, KI-Guidelines für KMU, 3rd edition, April 2026, pp. 5, 11, 14, 17, 20, 26, 29, 33, 39 · wko.at · retrieved 2026-10-18; Regulation (EU) 2024/1689, Art. 4 and Art. 113, consolidated version of 27 July 2026 · retrieved 2026-10-19

◆ INTERPRETATION The model is well made and comes from the body an Austrian business turns to anyway. A business may use its wording where it fits better, and the nine areas of this toolkit as the frame, because here every open field is explained. The model has no register, no approval form, no attendance list, no checklist per publication and no plan with a review date; those are the parts this toolkit adds. Whoever copies a sentence that names a deadline checks the date of the publication first and the Regulation second.

■ FACT The AI service centre at the regulator RTR is, by its own description, a contact point and information hub for the public that supports the implementation of the AI Act; its legal basis is § 20c KOG and § 194a TKG. Its pages name no market surveillance or sanctioning powers. Its press release of 2 July 2026 on Article 50 names no authority either.

→ Source: RTR, KI-Servicestelle, legal basis and role; press release of 2 July 2026 · rtr.at · retrieved 2026-10-19

FACT The Austrian data protection authority writes on its AI page that it has not yet been fixed who will be the market surveillance authority in Austria, that it is itself competent for data protection questions concerning AI systems, and that under Article 74(8) of the AI Act it acts as market surveillance authority for certain high-risk systems in law enforcement, border management, justice and democratic processes. A parliamentary motion titled "Finally name the AI authority", introduced on 15 October 2025, was adjourned in committee on 3 June 2026. Two web searches on 18 and 19 October 2026 found no act in the Federal Law Gazette that designates the authority.

→ Source: Datenschutzbehörde, Künstliche Intelligenz und Datenschutz, undated · dsb.gv.at · retrieved 2026-10-19; Austrian Parliament, motion 517/A(E), XXVIII. GP · parlament.gv.at · retrieved 2026-10-19

◐ UNCERTAIN

Who supervises Article 4 and Article 50 in Austria, and with which penalties?

As of 19 October 2026 no official source names the market surveillance authority for the AI Act in Austria. The labelling checklist therefore names no authority and no penalty and leaves a dated field for it. The duties themselves apply regardless, because the Regulation is directly applicable.

LAST CHECKED 2026-10-19 · OPEN POINT 8.4

7.2 Germany

FACT The guidance of the data protection authorities and the BSI document cited throughout this handbook are German. Germany has designated its authority: the Act on market surveillance and innovation promotion of artificial intelligence of 22 July 2026 is in force since 29 July 2026. Its § 2(1) names the Federal Network Agency as the market surveillance authority for compliance with the AI Act, § 6(1) makes it the central contact point and § 8(1) the central complaints body; § 9(4) requires the market surveillance authorities to involve the data protection authorities of the federation and the states.

→ Source: KI-Marktüberwachungs- und Innovationsförderungsgesetz of 22 July 2026, BGBl. 2026 I No. 223, §§ 2, 6, 8, 9 · gesetze-im-internet.de, marked there as not yet documentarily processed · retrieved 2026-10-19

◐ UNCERTAIN The exact split between the Federal Network Agency and sector authorities was not read; the published text carries the note that it is not yet documentarily processed. Whether an AI tool triggers co-determination of the works council is a question of German labour law that this handbook did not survey.

7.3 Other member states

◌ GAP The toolkit did not search for authorities, guidance or co-determination rules in other member states. What applies everywhere: Article 4, Article 50 and the Commission's guidelines and questions and answers. What does not: the German and Austrian recommendations, which the handbook marks as such wherever it uses them. A business elsewhere checks its own chamber or data protection authority for a model and asks who the market surveillance authority is; the Commission publishes a list of the national authorities, which this handbook has not verified and therefore does not cite as a source.

8 Open points

The old evidence kit listed fourteen uncertainties. Each was checked again at the originals on 18 and 19 October 2026. Three new ones were added.

No.	Question	Status on 19 October 2026
8.1	Was the wording of Article 50 read at the Official Journal?	Resolved. English and German consolidated text read at EUR-Lex; the wording in sections 5 and 10 is from the original.
8.2	Were the Commission's guidelines read in full?	Resolved. Full text with paragraph numbers; the checklist cites points 38 and 154.
8.3	Was the German wording of Art. 50(7) and Art. 111(4) read?	Resolved. German consolidated version read.
8.4	Which authority supervises in Austria, with which penalties?	Open. See 7.1. Germany resolved, see 7.2.
8.5	Does the business have an own duty when it embeds a provider's chatbot?	Partly. Paragraph 1 remains a provider duty; the guidelines settle the deployer role, not this question. Remains interpretation.
8.6	What are "matters of public interest" for a small business?	Largely settled by point 131 of the guidelines with examples; mixed texts remain interpretation and are treated as covered in case of doubt.
8.7	Are the nine areas an official catalogue?	No, and the handbook says so. A business may merge or add areas without missing anything a source requires.
8.8	Is release by a second person or the no-consequence reporting channel required anywhere?	No source requires either. Both stand on interpretation, sections 2.6 and 2.8.
8.9	How often is the briefing repeated, how long is the record kept?	Gap. No source states a rhythm or a retention period.
8.10	Does the policy bind freelancers and contractors?	Article 4 covers persons under the organisational remit; how a policy binds them is contract law and was not surveyed. The overview lists them.
8.11	Does an AI tool trigger co-determination?	National law. The plan points to a specialist, section 6.

No.	Question	Status on 19 October 2026
8.12	Is a policy a reasonable step to keep trade secrets?	No court decision searched. Section 1.
8.13	Were the sources reopened?	Resolved. All sources read again on 18 and 19 October 2026 with the retrieval date next to each.
8.14	Does the wording match the earlier handbook volume?	Resolved. That volume was never delivered; this handbook is now the primary text and refers to no other.
8.15	New: the Commission's page gives both 2 and 3 August 2026 for the start of supervision of Article 4.	Recorded in section 4; the handbook uses 2 August 2026.
8.16	New: a corrigendum to Regulation (EU) 2026/1744 of 29 September 2026 is incorporated in the consolidated text.	Its content was not read separately; the consolidated text of 27 July 2026 as shown by EUR-Lex on 19 October 2026 is what the handbook quotes.
8.17	New: the German act is published with the note "not yet documentarily processed".	Section 7.2 quotes it with that note.

9 Glossary

AI system. A machine-based system designed to operate with varying levels of autonomy that infers from its input how to generate outputs such as predictions, content, recommendations or decisions (Art. 3(1) AI Act). In this toolkit: a tool.

Provider. Who develops an AI system or has it developed and places it on the market or puts it into service under its own name or trademark (Art. 3(3)).

Deployer. Who uses an AI system under its authority, except in a personal non-professional activity (Art. 3(4)). The business is the deployer; its employees are not.

AI literacy. Skills, knowledge and understanding that allow providers, deployers and affected persons to make an informed deployment of AI systems and to gain awareness of opportunities, risks and possible harm (Art. 3(56)).

Deep fake. AI-generated or manipulated image, audio or video content that resembles existing persons, objects, places, entities or events and would falsely appear to a person to be authentic or truthful (Art. 3(60)).

High-risk AI system. A system listed in Annex III, for example in recruitment and workers' management, or covered by Annex I. Duties for Annex III systems apply from 2 December 2027. The policy excludes such uses.

Consolidated version. The text of a regulation with all amendments worked in, published by EUR-Lex as a documentation tool. The handbook quotes the consolidated AI Act of 27 July 2026.

Data processing agreement. The contract under Art. 28(3) GDPR between the business as controller and a provider that processes personal data on its behalf.

Training with business data. The use of inputs by a provider to train or improve its models. Question 1 of the approval check; excludable in business tariffs of many providers, to be checked at the provider.

Input history. The stored record of a person's inputs in a tool. The guidance recommends switching it off beyond the session when the account is set up.

Functional address. An email address of the business that names a function, not a person, used for business accounts.

Account kind. In the register: business (set up by the business, functional address), shared (one account for several people), private (set up by the person), or unknown.

Approval. The documented decision of the management that a tool may be used for work: without restriction, with restriction, or not at all, with date, reason and review date.

Approval check. The check of a tool against the seven questions, evidenced at the provider's page or contract with a date.

Register. The tool register: the list of all AI tools used in the business with kind, purpose, users, account kind, data kinds, approval, review date and review due.

Rule of doubt. The sentence that covers the case no catalogue meets: in case of doubt nothing is entered, the named person is asked.

Effective date. The date from which the policy applies in the business. It should lie after the briefing.

Acknowledgement. The dated confirmation of a person that they received and read the policy; a column of the overview per person.

Version line. The line with the date that says which version of a document is in hand.

Labelling. The disclosure that content was artificially generated or manipulated, or the notice that a person interacts with an AI system (Art. 50).

Evidence. A sheet that shows with date and signature that something was regulated, checked or carried out. It does not show that what was regulated is legally sufficient.

Review. The date on which a piece of evidence is looked at again, and the occasions that trigger an earlier review.

Market surveillance authority. The national authority that supervises the AI Act under Article 70 and following. Designated in Germany; not yet designated in Austria as of 19 October 2026.

Gap. In this toolkit: a field the business fills itself, with a sentence next to it that says what the decision means and where the handbook explains it.

10 Sources

All sources were read at the originals on 18 and 19 October 2026. EUR-Lex texts were opened in a browser and the article text was copied from the page; the PDF documents were downloaded and searched by page. The retrieval date stands next to every statement in this handbook.

Union law

1. Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 (AI Act), consolidated version 02024R1689 of 27 July 2026, English and German, including the amendments by Regulation (EU) 2026/1744 and the corrigenda of 9 October 2025 and 29 September 2026. Art. 2(10); Art. 3(1), (3), (4), (56), (60); Art. 4; Art. 5(1); Art. 26; Art. 50; Art. 99; Art. 111; Art. 113; Annex III point 4. eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:02024R1689-20260727 · retrieved 2026-10-18 and 2026-10-19.
2. Regulation (EU) 2026/1744 of the European Parliament and of the Council of 8 July 2026 amending Regulations (EU) 2024/1689, (EU) 2018/1139 and (EU) 2023/1230 as regards the simplification of the implementation of harmonised rules on artificial intelligence (Digital Omnibus on AI), OJ L, 2026/1744, 24.7.2026, in force since 27 July 2026. Art. 1, points (5), (20), (39), (40). eur-lex.europa.eu/eli/reg/2026/1744/oj · retrieved 2026-10-18.
3. Regulation (EU) 2016/679 (General Data Protection Regulation), consolidated version 02016R0679 of 4 May 2016. Art. 24(1), Art. 28(3), Art. 88(1). eur-lex.europa.eu/legal-content/EN/TXT/HTML/?uri=CELEX:02016R0679-20160504 · retrieved 2026-10-19.
4. Directive (EU) 2016/943 of the European Parliament and of the Council of 8 June 2016 on the protection of undisclosed know-how and business information (trade secrets). Art. 1(3), Art. 2(1). eur-lex.europa.eu/eli/dir/2016/943/oj/eng · retrieved 2026-10-18.

European Commission

5. Guidelines on the implementation of the transparency obligations for certain AI systems under Article 50 of Regulation (EU) 2024/1689, Annex to the Communication to the Commission C(2026) 5054 final, Brussels, 20 July 2026, 51 pages. Points 12 to 16, 38, 112, 130 to 138, 144, 153, 154. digital-strategy.ec.europa.eu/en/library/guidelines-transparency-obligations-providers-and-deployers-ai-systems · retrieved 2026-10-19. Guidance, not law.

6. AI literacy, questions and answers, page dated 27 July 2026. digital-strategy.ec.europa.eu/en/faqs/ai-literacy-questions-answers · retrieved 2026-10-18. Guidance, not law.

Supervisory authorities and expert bodies

7. Konferenz der unabhängigen Datenschutzaufsichtsbehörden des Bundes und der Länder (Datenschutzkonferenz, Germany), Orientierungshilfe Künstliche Intelligenz und Datenschutz, version 1.0 of 6 May 2024, 15 pages. Sections 1.9, 1.10, 1.12, 2.2, 2.4, 2.5, 3.1. datenschutzkonferenz-online.de/media/oh/20240506_DSK_Orientierungshilfe_KI_und_Datenschutz.pdf · retrieved 2026-10-18.
8. Bundesamt für Sicherheit in der Informationstechnik (Germany), Generative KI-Modelle, Chancen und Risiken für Industrie und Behörden, version 2.0 of 17 January 2025, 71 pages. Measure M16, p. 49. bsi.bund.de/SharedDocs/Downloads/DE/BSI/KI/Generative_KI-Modelle.pdf · retrieved 2026-10-18.
9. Datenschutzbehörde (Austria), Künstliche Intelligenz und Datenschutz, undated page. dsb.gv.at/kuenstlichebrintelligenz/kuenstliche-intelligenz-datenschutz · retrieved 2026-10-19.
10. Rundfunk und Telekom Regulierungs-GmbH (RTR, Austria), KI-Servicestelle, legal basis and role, and press release of 2 July 2026 on the transparency obligations of Article 50. rtr.at · retrieved 2026-10-19.

Chambers and parliaments

11. Wirtschaftskammer Österreich, KI-Guidelines für KMU, 3rd edition, April 2026, 41 pages. Pages 2, 5, 11, 14 to 27, 29, 32, 33, 39. wko.at/noe/digitalisierung/ki-guidelines/ki-guidelines.pdf · retrieved 2026-10-18.
12. Austrian Parliament, motion 517/A(E), XXVIII. GP, "KI-Behörde endlich benennen", introduced 15 October 2025, adjourned 3 June 2026. parlament.gv.at/gegenstand/XXVIII/A/517 · retrieved 2026-10-19.
13. Gesetz zur Marktüberwachung und Innovationsförderung von künstlicher Intelligenz (KI-MIG, Germany) of 22 July 2026, BGBl. 2026 I No. 223, in force since 29 July 2026. §§ 2, 6, 8, 9. gesetze-im-internet.de/ki-mig/BJNR0DF0B0026.html, marked as not yet documentarily processed · retrieved 2026-10-19.